Relatório de teste: segurança (pentest)

SafeID · Commit f9677df da main · Executado em 03/11/2026 · Horários em UTC

> **Resultado: sem achado alto ou crítico em aberto.** O achado S01, com 6 pacotes altos nas dependências, foi corrigido pelo PR #123: o `npm audit --omit=dev` do back-end passou de 6 altos e 7 moderados para **0 altos e 3 moderados**, estes justificados. As varreduras, o fuzzing e os testes dirigidos não encontraram falha explorável. Resta o achado médio S07 (limite de login contornável por cabeçalho forjado), recomendado corrigir. O critério da Seção 6.3 do documento ("nenhum achado de severidade alta ou crítica em aberto") **passa a estar cumprido**.

Nota: a correção de dependências está na `main` (f9677df), mas ainda não foi para produção, que roda a imagem anterior. O novo deploy a leva.

Escopo e autorização

- Autorizado pela equipe, dona do sistema, apenas sobre os domínios e a infraestrutura do próprio projeto.
- **Em produção:** só testes de baixo impacto: varredura passiva, verificações dirigidas e a prova do S07, com poucas requisições.
- **Em cópia local descartável:** varredura ativa, autorização e fuzzing de entrada, com PostgreSQL e Redis próprios, HIBP simulada, e-mail só em log.
- **Fora do escopo:** negação de serviço, engenharia social e testes na infraestrutura da AWS.

Ferramentas

- OWASP ZAP 2.17.0: `zap-baseline`, `zap-api-scan` e `zap-full-scan`.
- Scripts versionados: `tests/security/verificacoes.py`, `autorizacao_local.py` e `fuzz_entrada.py`.
- `npm audit --omit=dev` no back-end e no front-end.

Verificações dirigidas em produção: 50 de 50 aprovadas

Categoria	Verificações	Aprovadas
Transporte	6	6
Cabeçalhos	12	12
CORS	1	1
Autenticação	12	12
Entrada	7	7
Exposição	9	9
Enumeração	1	1
Limite de tentativas	2	2

Cobrem TLS e redirecionamento HTTPS, cabeçalhos, CORS, rotas sem login, JWT forjado (alg none e assinatura falsa), injeção SQL e NoSQL no login, campos extras, exposição de arquivos, enumeração de contas e bloqueio após tentativas de login.

Autorização entre usuários, em cópia local: 11 de 11 aprovadas

Verificação	Resultado
o dono lê a própria análise	**Aprovada**
outro usuário não lê a análise pelo jobId	**Aprovada**
o histórico de outro usuário não aparece	**Aprovada**
outro usuário não marca a notificação alheia	**Aprovada**
a notificação alheia segue não lida	**Aprovada**
o dono marca a própria notificação	**Aprovada**
o refresh token não vale como acesso	**Aprovada**
o token de acesso não vale como refresh	**Aprovada**
a exportação traz só a própria conta	**Aprovada**
a exclusão só apaga a conta do token	**Aprovada**
token de conta apagada deixa de valer	**Aprovada**

Fuzzing de entrada, em cópia local

O script `fuzz_entrada.py` enviou 400 requisições, injetando 22 tipos de carga maliciosa (SQL, NoSQL, poluição de protótipo, XSS, comando, travessia de caminho, template, nulo, tipos trocados, 100 KB e corpo de 2 MB) em cada campo JSON de 10 rotas, nos parâmetros de caminho e de consulta. Resultado: **0 problema(s)**. Nenhum 5xx, nenhum detalhe interno na resposta, nenhum XSS refletido; a API seguiu respondendo ao final. As respostas foram 13×200, 17×201, 251×400, 107×401, 10×413 (400, 401 e 413 são as recusas esperadas).

Varreduras do ZAP (número de tipos de alerta)

Alvo	Modo	Alto	Médio	Baixo	Informativo
www.safeid.app.br (produção)	Passivo	0	1	4	4
api.safeid.app.br (produção)	Passivo	0	0	0	2
API local, autenticada	Ativo	0	0	2	3
Front local	Ativo	0	1	0	1

A varredura ativa da API importou 28 endereços do OpenAPI e, confirmado por um proxy contador, enviou 454 requisições reais à aplicação (incluindo os ataques das regras ativas), não apenas as rotas listadas.

Achados

ID	Severidade	Achado	Situação e recomendação
S01	Alta	npm audit: 6 pacotes altos e 7 moderados nas dependências de produção do back-end (na campanha anterior).	**Resolvido (PR #123):** 0 altos e 3 moderados. Os moderados vêm de um único aviso de SSE no @nestjs/core, sem rota @Sse na aplicação.

ID	Severidade	Achado	Situação e recomendação
S07	Média	O limite de tentativas de login é contado pelo primeiro IP do X-Forwarded-For, que o cliente controla. Em produção, 12 tentativas com IP forjado diferente a cada vez não dispararam o 429.	**Em aberto.** Confiar apenas no X-Forwarded-For escrito pelo ALB/CloudFront (número fixo de proxies), ou limitar também por e-mail/rota. Mitiga força bruta distribuída.
S02	Média	CSP do site com style-src 'unsafe-inline'.	Aceito: exigido por React e Tailwind. script-src é só 'self', o que limita o impacto.
S03	Baixa	Cabeçalhos COOP, COEP e CORP ausentes no site.	Recomendado incluir COOP e CORP na política do CloudFront. COEP não é necessário.
S04	Baixa	GET /scan/:jobId de outro usuário responde 200 com corpo vazio.	Sem vazamento: a consulta filtra por userId. Recomendado responder 404.
S05	Baixa	Cabeçalho 'Server: AmazonS3' no site.	Aceito: não expõe versão.
S06	Baixa	Redis sem TLS nem criptografia em repouso.	Já conhecido, na rede privada. Dados do cache usam HMAC. Avaliar ao sair do plano atual.
—	Descartados	'HTTP Only Site' (efeito do ambiente local) e 'Timestamp Disclosure' (datas legítimas no JSON).	Falsos positivos, sem ação.

Prova do S07 (produção)

Do mesmo IP, a 6ª tentativa de login já recebe 429 (401, 401, 401, 401, 401, 429, 429). Com um X-Forwarded-For diferente a cada tentativa, as 12 passam sem 429 (401, 401, 401, 401, 401, 401, 401, 401, 401, 401, 401, 401). Evidência em `docs/testes/dados/xff-bypass.json`.

Moderados restantes nas dependências

Severidade	Pacote	Aviso	Alcançável
moderate	@nestjs/core	@nestjs/core Improperly Neutralizes Special Elements in Output Used by	Não: exige endpoint @Sse, inexistente no código

Os alertas completos estão em `docs/testes/dados/npm-audit-server.json`.

Incidente durante o teste

> Na primeira varredura ativa, o ZAP seguiu o redirecionamento de `/api/v1/auth/google` e enviou dezenas de requisições a `accounts.google.com`, **fora do escopo autorizado**. O client_id era um valor de exemplo, sem credenciais. A rota foi excluída das varreduras seguintes, e os resultados do domínio do Google foram descartados dos dados.

Limitações

- **Não substitui um pentest manual por terceiros:** o teste é automatizado, com verificações dirigidas pela própria equipe, e não prova ausência de falhas.

- Os limites por rota (login 5 por minuto, cadastro 5 a cada 15 minutos) continuaram ativos na cópia local, o que reduz a cobertura do ZAP nessas rotas.
- Os fluxos com HIBP real, IA e login com Google não passaram pela varredura ativa.

Como repetir

Ver `docs/testes/README.md`. Dados brutos em `docs/testes/dados/`.